

**TEMPLATE
PROJECT WORK**

Corso di Studio	INFORMATICA PER LE AZIENDE DIGITALI (L-31)
Dimensione dell'elaborato	Minimo 6.000 – Massimo 10.000 parole (<i>pari a circa Minimo 12 – Massimo 20 pagine</i>)
Formato del file da caricare in piattaforma	PDF
Nome e Cognome	Giacomo Guerra
Numero di matricola	0312500522
Tema n. (Indicare il numero del tema scelto):	2
Titolo del tema (Indicare il titolo del tema scelto):	Privacy e sicurezza aziendale
Traccia del PW n. (Indicare il numero della traccia scelta):	19
Titolo della traccia (Indicare il titolo della traccia scelta):	Progettare e realizzare una base dati relazionale per catalogare asset, servizi, dipendenze e responsabilità utili alla compilazione dei profili richiesti dall'ACN nell'ambito della NIS2.
Titolo dell'elaborato (Attribuire un titolo al proprio elaborato progettuale):	Base di dati relazionale per la gestione del profilo NIS2/ACN

PARTE PRIMA – DESCRIZIONE DEL PROCESSO

Utilizzo delle conoscenze e abilità derivate dal percorso di studio

(Descrivere quali conoscenze e abilità apprese durante il percorso di studio sono state utilizzate per la redazione dell'elaborato, facendo eventualmente riferimento agli insegnamenti che hanno contribuito a maturarle):

La realizzazione dell'elaborato ha richiesto l'integrazione di competenze maturate in più insegnamenti del corso di laurea in Informatica per le Aziende Digitali, con particolare riferimento al corso di Basi di Dati. Il lavoro ha inoltre offerto l'occasione di mettere in relazione conoscenze teoriche e capacità operative, traducendo un problema di dominio complesso in un artefatto software concreto, documentato e verificabile.

Le conoscenze di Basi di Dati hanno costituito il nucleo metodologico del progetto. La modellazione concettuale tramite diagramma Entità-Relazione ha permesso di individuare le entità del dominio (organizzazioni, asset, servizi, fornitori, contratti, persone) e le loro associazioni; la successiva traduzione nel modello logico relazionale ha portato alla definizione delle tabelle, delle chiavi primarie ed esterne e dei vincoli. La teoria della normalizzazione (prima, seconda e terza forma normale) è stata applicata per eliminare ridondanze e anomalie di aggiornamento, mentre il linguaggio SQL è stato utilizzato nelle sue componenti di definizione dei dati (DDL), manipolazione (DML) e interrogazione, comprese funzioni aggregate, sottoquery, viste e funzioni di finestra applicate alla generazione dei profili.

Dall'area dei Sistemi di elaborazione delle informazioni derivano le nozioni relative all'architettura dei sistemi di gestione di basi di dati (DBMS), all'organizzazione fisica dei dati e alle strutture di

indicizzazione. In particolare, la comprensione degli indici B-tree e degli indici parziali è stata determinante per progettare una strategia di indicizzazione coerente con le interrogazioni più frequenti; allo stesso modo, la conoscenza dei meccanismi transazionali e dei trigger ha reso possibile l'implementazione di un registro automatico e affidabile delle modifiche.

Le competenze in materia di sicurezza informatica e protezione dei dati hanno consentito di inquadrare il contesto normativo della direttiva NIS2 e del Regolamento generale sulla protezione dei dati, di classificare gli asset in base alla criticità, di modellare le dipendenze dalla catena di fornitura e di riconoscere l'importanza di un registro auditabile delle modifiche ai fini della conformità e della gestione del rischio.

Infine, le abilità di ingegneria del software sono state impiegate per organizzare il progetto come repository versionabile, per separare in modo ordinato gli script di struttura, di popolamento e di estrazione, per redigere la documentazione tecnica (diagramma ER e data dictionary) e per adottare pratiche di tracciabilità delle modifiche e di gestione delle versioni del prodotto.

Sul piano operativo, il percorso di studio ha fornito anche le competenze necessarie a verificare il prodotto: la definizione di un dataset di prova, il controllo dei vincoli di integrità e il confronto tra i risultati attesi e quelli ottenuti dalle interrogazioni. Tali abilità hanno consentito di procedere in modo iterativo, correggendo e affinando lo schema fino alla versione definitiva, e di documentare in modo rigoroso le scelte compiute, come richiesto da un approccio ingegneristico alla progettazione del software.

Fasi di lavoro e relativi tempi di implementazione per la predisposizione dell'elaborato

(Descrivere le attività svolte in corrispondenza di ciascuna fase di redazione dell'elaborato. Indicare il tempo dedicato alla realizzazione di ciascuna fase, le difficoltà incontrate e come sono state superate):

Il lavoro è stato organizzato in fasi successive, secondo un approccio incrementale che, dopo una prima versione completa, ha previsto una revisione complessiva sfociata nella versione 1.1 dello schema. Complessivamente l'attività ha richiesto circa quattro settimane di lavoro non continuativo, ripartite fra le fasi descritte di seguito.

La prima fase, di analisi dei requisiti (circa tre giorni), ha riguardato lo studio della traccia e della documentazione relativa a NIS2 e all'ACN, con l'individuazione delle entità informative necessarie (asset, servizi, dipendenze, responsabilità, referenti e misure di sicurezza) e dei requisiti trasversali di versionamento e di esportazione dei dati.

La seconda fase, di progettazione concettuale (circa due giorni), ha prodotto il diagramma Entità-Relazione con 16 entità e 27 relazioni di integrità referenziale, verificando la copertura di tutte le sezioni del profilo richiesto dall'ACN.

La terza fase, di progettazione logica e normalizzazione (circa tre giorni), ha tradotto il modello concettuale in schema relazionale, verificando il rispetto della terza forma normale e definendo chiavi, vincoli di dominio (CHECK), vincoli di unicità e le denormalizzazioni controllate ritenute utili all'efficienza.

La quarta fase, di implementazione su PostgreSQL (circa quattro giorni), ha comportato la scrittura degli script di definizione dei dati (creazione di tabelle, indici e vincoli), delle funzioni trigger per l'audit e per l'aggiornamento automatico dei timestamp e delle viste destinate alla generazione del profilo.

La quinta fase, di popolamento con dati di test (circa due giorni), ha prodotto un dataset rappresentativo di cinque organizzazioni appartenenti a settori diversi, per un totale di circa trecentoundici record, tale da consentire la verifica delle interrogazioni in condizioni realistiche.

La sesta fase, di sviluppo delle interrogazioni di estrazione (circa tre giorni), ha portato alla definizione di tredici query e dei relativi comandi di esportazione in formato CSV, con la generazione automatica dei file per ciascuna organizzazione.

La settima fase, di documentazione (circa tre giorni), ha prodotto il documento tecnico comprensivo di diagramma ER, data dictionary, descrizione delle scelte di normalizzazione e istruzioni di installazione.

L'ultima fase, di revisione e refactoring corrispondente alla versione 1.1 (circa due giorni), ha introdotto una serie di miglioramenti emersi da una verifica complessiva: l'estensione dell'audit trail con la registrazione dell'autore della modifica e di ulteriori campi (versione del software e indirizzo IP), l'introduzione di indici univoci parziali a garanzia di un solo proprietario attivo per asset e per servizio, la riscrittura della vista di riepilogo con sottoquery scalari per eliminare un prodotto cartesiano e la separazione fra script di struttura e script di popolamento.

Tra le principali difficoltà incontrate si segnalano la gestione delle chiavi esterne facoltative, risolta con un vincolo CHECK che impone la valorizzazione di almeno una fra asset e servizio; la corretta progettazione del meccanismo di storicizzazione, risolta con un trigger BEFORE UPDATE che confronta i valori precedenti e nuovi; e l'ottimizzazione delle interrogazioni di riepilogo, risolta sostituendo le aggregazioni su join multipli con sottoquery scalari indipendenti. Ciascuna difficoltà è stata affrontata verificando la soluzione sui dati di test prima di consolidarla.

Complessivamente, l'articolazione in fasi ha permesso di procedere in modo controllato, verificando i risultati di ciascuna fase prima di passare alla successiva e riducendo il rischio di dover rivedere a posteriori scelte fondamentali.

Risorse e strumenti impiegati

(Descrivere quali risorse - bibliografia, banche dati, ecc. - e strumenti - software, modelli teorici, ecc. - sono stati individuati ed utilizzati per la redazione dell'elaborato. Descrivere, inoltre, i motivi che hanno orientato la scelta delle risorse e degli strumenti, la modalità di individuazione e reperimento delle risorse e degli strumenti, le eventuali difficoltà affrontate nell'individuazione e nell'utilizzo di risorse e strumenti ed il modo in cui sono state superate):

Per la redazione dell'elaborato sono state impiegate risorse documentali e strumenti software, selezionati in funzione degli obiettivi del progetto e descritti di seguito.

Sul piano normativo e di dominio sono stati consultati il testo della direttiva (UE) 2022/2555 (NIS2) e il decreto legislativo 138/2024 di recepimento, oltre alla documentazione dell'Agenzia per la Cybersicurezza Nazionale relativa ai profili dei soggetti e alle misure di sicurezza previste dall'articolo 21. Tali fonti hanno guidato l'individuazione delle informazioni da modellare e la definizione delle categorie e degli stati utilizzati nello schema.

Lo schema è stato implementato su PostgreSQL, nella versione 14 o superiore, scelto per la maturità, la conformità allo standard SQL e il supporto a funzionalità avanzate quali i tipi SERIAL e TIMESTAMPTZ, i vincoli CHECK, gli indici parziali, i trigger scritti in linguaggio PL/pgSQL e il comando COPY per l'esportazione dei dati. Le interrogazioni e le esportazioni sono state eseguite tramite il client a riga di comando psql, mentre per l'ispezione visiva dello schema e dei dati è stato utilizzato lo strumento grafico pgAdmin.

Per la modellazione e la documentazione sono stati prodotti il diagramma Entità-Relazione e il data dictionary. Il progetto è stato strutturato come repository versionabile con Git, articolato in file

distinti e complementari: uno script di struttura contenente le definizioni (nis2_schema.sql), uno script di popolamento con i dati di test (nis2_testdata.sql), uno script di estrazione con le interrogazioni e i comandi di esportazione (nis2_export_csv.sql) e la documentazione tecnica. Questa organizzazione tiene separata la struttura dai dati e ne favorisce la manutenzione e il riutilizzo.

Sul piano metodologico si è fatto riferimento ai principi della teoria relazionale e della normalizzazione, ai pattern di progettazione per l'audit trail e la storicizzazione dei dati e alle buone pratiche di scrittura del codice SQL, quali la denominazione coerente degli oggetti, l'uso di commenti e l'idempotenza degli script. La principale difficoltà nel reperimento delle informazioni ha riguardato la traduzione dei requisiti del profilo ACN, espressi in linguaggio normativo, in un modello dati operativo; essa è stata affrontata adottando una rappresentazione semplificata ma estensibile, in grado di coprire le sezioni fondamentali del profilo.

La scelta di PostgreSQL, in luogo di soluzioni più leggere, è stata motivata anche dalla necessità di funzionalità tipiche dei sistemi professionali: l'integrità referenziale con azioni referenziali configurabili, il supporto nativo ai trigger e alle funzioni, la ricchezza delle funzioni aggregate e di finestra e la possibilità di definire viste complesse. Lo strumento pgAdmin ha affiancato il client a riga di comando nelle attività di verifica, consentendo di esplorare visivamente l'albero degli oggetti, di ispezionare le tabelle e di eseguire interrogazioni di controllo. Particolare attenzione è stata dedicata alla codifica dei caratteri e al separatore dei file esportati, per garantire la corretta apertura dei dati nei fogli di calcolo, predisponendo a tale scopo varianti di esportazione adatte a contesti diversi.

L'adozione di un sistema di controllo di versione ha infine permesso di tenere traccia dell'evoluzione del progetto e di gestire in modo ordinato il passaggio dalla prima versione alla revisione finale, mantenendo separati e riconoscibili i diversi artefatti prodotti.

Gli script SQL e la documentazione tecnica sono versionati in un repository Git insieme a file CSV di test ottenuti dalle interrogazioni al database popolato con dati di esempio, disponibili all'indirizzo: <https://github.com/PWRJack/Nis2-db>. Una copia dei file dell'elaborato è inoltre reperibile nella cartella condivisa al seguente indirizzo: https://drive.google.com/drive/folders/1pqIs3VNaQDDqZTrelvKedhVlV5NnJRjI?usp=drive_link.

Fonti e riferimenti

Le principali fonti consultate per la redazione dell'elaborato sono le seguenti.

- Direttiva (UE) 2022/2555 del Parlamento europeo e del Consiglio, del 14 dicembre 2022, relativa a misure per un livello comune elevato di cibersecurity nell'Unione (direttiva NIS2), in Gazzetta ufficiale dell'Unione europea L 333 del 27 dicembre 2022.
- Decreto legislativo 4 settembre 2024, n. 138, recante il recepimento della direttiva (UE) 2022/2555, in Gazzetta Ufficiale della Repubblica Italiana n. 230 del 1° ottobre 2024.
- Agenzia per la Cybersecurity Nazionale (ACN), documentazione e materiali informativi relativi ai soggetti e agli obblighi previsti dalla NIS2 (sito istituzionale [acn.gov.it](https://www.acn.gov.it)).
- The PostgreSQL Global Development Group, PostgreSQL Documentation (versione 14 e successive), disponibile all'indirizzo <https://postgresql.org/docs>.
- Riferimenti sul modello relazionale e sulla teoria della normalizzazione, in particolare E. F. Codd, «A Relational Model of Data for Large Shared Data Banks», Communications of the ACM, 1970, e la successiva letteratura sulle forme normali.

- Framework Nazionale per la Cybersecurity e la Data Protection, edizione 2025 (versione 2.1), CIS Sapienza e Laboratorio Nazionale di Cybersecurity CINI (<https://www.cybersecurityframework.it>).

PARTE SECONDA – PREDISPOSIZIONE DELL'ELABORATO

Obiettivi del progetto

(Descrivere gli obiettivi raggiunti dall'elaborato, indicando in che modo esso risponde a quanto richiesto dalla traccia):

L'elaborato risponde puntualmente agli obiettivi indicati dalla traccia, di seguito richiamati e messi in relazione con quanto effettivamente realizzato. L'obiettivo generale consisteva nel progettare e realizzare una base dati relazionale in grado di catalogare asset, servizi, dipendenze e responsabilità a supporto della compilazione dei profili richiesti dall'ACN nell'ambito della direttiva NIS2.

Il primo obiettivo specifico, relativo all'analisi dei requisiti e alla loro traduzione in un modello concettuale, è stato conseguito analizzando i requisiti informativi del profilo ACN e rappresentandoli in un diagramma Entità-Relazione con sedici entità e ventisette relazioni.

Il secondo obiettivo, riguardante la progettazione di uno schema relazionale normalizzato con supporto al versionamento e allo storico, è stato raggiunto definendo uno schema in terza forma normale, dotato di un meccanismo di storicizzazione automatica delle modifiche agli asset (tabella di storico alimentata da un trigger) e di versionamento del profilo ACN con un ciclo di vita esplicito.

Il terzo obiettivo, relativo all'implementazione dello schema su un sistema di gestione di basi di dati con indici e vincoli, è stato conseguito realizzando lo schema su PostgreSQL con chiavi primarie ed esterne, vincoli CHECK, vincoli di unicità, indici B-tree e indici parziali, a garanzia dell'integrità e delle prestazioni.

Il quarto obiettivo, riguardante la scrittura di interrogazioni capaci di generare porzioni del profilo ACN, è stato raggiunto realizzando nove viste e tredici interrogazioni che estraggono, per ciascuna organizzazione, gli asset critici, i servizi erogati, le dipendenze dai fornitori terzi, i referenti e lo stato delle misure di sicurezza, con esportazione in formato CSV.

Il quinto obiettivo, relativo alla documentazione del modello, è stato conseguito attraverso un documento tecnico comprensivo di diagramma Entità-Relazione, data dictionary completo e istruzioni di deploy e manutenzione. Tutti gli obiettivi risultano pertanto conseguiti, e il prodotto consente di popolare in modo coerente e ripetibile le porzioni strutturate del profilo richiesto dall'ACN.

A tali obiettivi si aggiunge la rappresentazione dell'assessment secondo il Framework Nazionale: la base dati registra, per ciascuna Subcategory del Core, il livello target e il livello attuale di ogni organizzazione e ne calcola automaticamente il divario, restituendo una roadmap di intervento ordinata per priorità. Il prodotto non si limita così a fotografare la situazione esistente, ma supporta anche la pianificazione del percorso di adeguamento.

Il conseguimento di ciascun obiettivo è stato verificato in modo esplicito sui dati di test: la coerenza del modello è stata controllata mediante il caricamento completo del dataset e l'esecuzione delle interrogazioni di controllo, mentre la generazione delle porzioni del profilo è stata validata confrontando l'output delle viste con i valori attesi.

Il grado di copertura degli obiettivi è inoltre testimoniato dalla completezza degli artefatti prodotti, che comprendono lo schema, i dati di test, le interrogazioni di estrazione e la documentazione tecnica, tutti tra loro coerenti e allineati alla medesima versione del prodotto.

Contestualizzazione

(Descrivere il contesto teorico e quello applicativo dell'elaborato realizzato):

Dal punto di vista teorico, l'elaborato si colloca nell'ambito della progettazione di basi di dati relazionali e della sicurezza delle informazioni. La direttiva (UE) 2022/2555, nota come NIS2, aggiorna e amplia il precedente quadro europeo in materia di sicurezza delle reti e dei sistemi informativi, estendendo il novero dei soggetti obbligati e rafforzando gli obblighi di gestione del rischio e di notifica degli incidenti. In Italia la direttiva è stata recepita con il decreto legislativo 138/2024, che individua nell'Agenzia per la Cybersicurezza Nazionale (ACN) l'autorità competente.

La direttiva distingue i soggetti in due categorie: i soggetti essenziali e i soggetti importanti, individuati in base al settore di appartenenza e alla dimensione dell'organizzazione. I settori interessati comprendono, tra gli altri, l'energia, i trasporti, il settore bancario, le infrastrutture dei mercati finanziari, la sanità, la fornitura di acqua potabile, le infrastrutture digitali e la gestione dei servizi ICT, ai quali si aggiungono, per i soggetti importanti, ulteriori ambiti quali i servizi postali, la gestione dei rifiuti, la produzione e la fabbricazione. Lo schema progettato riflette tale distinzione attraverso appositi attributi che classificano ciascuna organizzazione per settore e per categoria.

Tra gli adempimenti previsti, l'ACN richiede la disponibilità di un profilo strutturato del soggetto, che comprende l'anagrafica dell'organizzazione e i relativi referenti, il perimetro dei servizi erogati (essenziali e digitali), l'inventario degli asset critici e importanti, le dipendenze dai fornitori terzi con riferimento alla sicurezza della catena di fornitura (articolo 21, paragrafo 2, lettera d) e lo stato di attuazione delle misure di sicurezza previste dall'articolo 21. Il profilo deve inoltre poter essere mantenuto aggiornato e versionato nel tempo.

Dal punto di vista applicativo, le organizzazioni gestiscono frequentemente queste informazioni in documenti, fogli di calcolo e sistemi non integrati, con conseguenti incoerenze, duplicazioni e difficoltà di aggiornamento e di esportazione. Ne derivano profili poco affidabili e onerosi da mantenere. L'elaborato affronta questo problema proponendo un registro centralizzato che modella in forma normalizzata gli asset, i servizi, le loro relazioni, i responsabili e i metadati necessari, e che consente di estrarre automaticamente le sezioni del profilo in formato strutturato, riducendo l'onere di compilazione e il rischio di errore.

L'articolo 21 della direttiva individua un insieme minimo di misure di gestione del rischio che i soggetti sono tenuti ad adottare, tra cui le politiche di analisi e gestione del rischio, la gestione degli incidenti, la continuità operativa e la gestione dei backup, la sicurezza della catena di approvvigionamento, la sicurezza nell'acquisizione e nella manutenzione dei sistemi, le procedure di valutazione dell'efficacia delle misure, le pratiche di igiene informatica e formazione, l'uso della crittografia, la sicurezza delle risorse umane e il controllo degli accessi, nonché l'impiego, ove opportuno, di soluzioni di autenticazione a più fattori. Lo schema progettato rende rappresentabili tali misure e il loro stato di attuazione, associandole agli asset o ai servizi cui si riferiscono.

La direttiva introduce inoltre obblighi di natura procedurale, in particolare per quanto riguarda la notifica degli incidenti significativi all'autorità competente entro tempi definiti, e responsabilizza gli organi di gestione, chiamati ad approvare le misure e a vigilare sulla loro attuazione. Sebbene la gestione del flusso di notifica degli incidenti esuli dal perimetro del presente elaborato, che si concentra sul profilo del soggetto, lo schema predispone comunque le informazioni di base a supporto di tali adempimenti, quali l'individuazione dei referenti e la mappatura degli asset e dei servizi critici.

In questo quadro, disporre di un profilo strutturato, aggiornato e auditabile non rappresenta un mero adempimento formale, ma una condizione abilitante per l'intero sistema di gestione della sicurezza: la conoscenza puntuale degli asset, delle loro dipendenze e delle responsabilità associate è il presupposto di ogni analisi del rischio e di ogni risposta efficace agli incidenti.

Rispetto alla precedente disciplina, la direttiva NIS2 amplia in modo significativo l'ambito di applicazione, includendo nuovi settori e adottando, in linea generale, un criterio dimensionale per l'individuazione dei soggetti obbligati, cui si affiancano specifiche eccezioni per i soggetti la cui attività è ritenuta particolarmente rilevante. Ne deriva che un numero molto maggiore di organizzazioni, rispetto al passato, è oggi chiamato a dotarsi di misure adeguate e a mantenere un profilo aggiornato: una circostanza che accresce l'utilità di strumenti in grado di sistematizzare e automatizzare la gestione delle relative informazioni.

Accanto alla direttiva NIS2, il quadro di riferimento nazionale comprende il Framework Nazionale per la Cybersecurity e la Data Protection, giunto all'edizione 2025, elaborato dal Centro di Ricerca di Cyber Intelligence and Information Security dell'Università Sapienza e dal Laboratorio Nazionale di Cybersecurity del CINI con il supporto dell'Agenzia per la Cybersicurezza Nazionale. Derivato dal Cybersecurity Framework del NIST, esso organizza le misure di sicurezza in un Core articolato in sei Funzioni — Governare, Identificare, Proteggere, Rilevare, Rispondere e Ripristinare — a loro volta suddivise in Categorie e Subcategory.

La metodologia di assessment associata al Framework prevede che l'organizzazione definisca un profilo target, che esprime il livello di sicurezza desiderato per ciascuna Subcategory, e rilevi un profilo attuale, che ne descrive lo stato effettivo. Il confronto fra i due profili individua gli scostamenti, ossia i gap, e consente di pianificare gli interventi secondo un ordine di priorità. Tale impostazione è complementare agli obblighi della NIS2: mentre la direttiva stabilisce che cosa il soggetto è tenuto a garantire, il Framework fornisce lo strumento con cui misurare quanto vi si sia effettivamente conformi.

Descrizione dei principali aspetti progettuali
(Sviluppare l'elaborato richiesto dalla traccia prescelta):

L'elaborato consiste in una base dati relazionale, implementata su PostgreSQL, composta da sedici tabelle, quattordici per il profilo NIS2 e due dedicate all'assessment, organizzate in quattro livelli logici. Questa suddivisione, oltre a rispecchiare la natura delle entità, rende lo schema più leggibile e manutenibile.

Il primo livello è costituito da una tabella di lookup, denominata tipo_asset, che classifica le tipologie di asset (server fisici e virtuali, apparati di rete, applicazioni, basi di dati, sistemi OT/ICS, dati e componenti fisiche) e che viene referenziata dalla tabella degli asset. Il secondo livello contiene le entità principali: organizzazione, sede, asset, servizio, fornitore e persona. Il terzo livello raccoglie le tabelle associative, che modellano le relazioni molti-a-molti e ternarie: asset_servizio, contratto, dipendenza e responsabilita. Il quarto livello, infine, riguarda l'audit e la governance e comprende le tabelle asset_storico, misura_sicurezza e profilo_acn.

L'entità organizzazione costituisce il punto di ingresso dello schema: ogni altra entità principale vi fa riferimento tramite una chiave esterna, cosicché tutte le informazioni risultano riconducibili al soggetto NIS2 di appartenenza. Lo schema comprende complessivamente ventisette relazioni di integrità referenziale, rappresentate nel diagramma Entità-Relazione con la notazione a piede di gallina (crow's foot), che evidenzia le cardinalità tra le entità. L'entità asset, in particolare, funge da secondo polo di aggregazione, essendo collegata allo storico delle modifiche, ai servizi supportati, alle dipendenze, alle responsabilità e alle misure di sicurezza.

Le entità principali modellano ciascuna un aspetto del profilo. La tabella asset rappresenta l'inventario delle risorse ICT, OT e informative, classificate per categoria (critico, importante o standard) e per stato operativo. La tabella servizio descrive i servizi erogati o gestiti, con i relativi obiettivi di continuità espressi come tempo e punto di ripristino (RTO e RPO). La tabella fornitore raccoglie le terze parti della catena di fornitura, con un attributo che segnala i fornitori critici. La tabella persona gestisce i referenti interni, tra cui il punto di contatto ufficiale verso l'ACN. Le tabelle associative, a loro volta, collegano tali entità: asset_servizio indica quali asset supportano quali servizi, contratto formalizza i rapporti con i fornitori con i relativi livelli di servizio, dipendenza rappresenta il nucleo della catena di fornitura collegando un asset o un servizio a un fornitore, e responsabilita assegna a ciascun asset o servizio un proprietario o un referente.

Un aspetto progettuale rilevante riguarda la modellazione delle dipendenze e delle responsabilità, che possono riferirsi indifferentemente a un asset oppure a un servizio. Le relative tabelle contengono due chiavi esterne facoltative, verso asset e verso servizio, governate da un vincolo di controllo che impone la valorizzazione di almeno una delle due. Questa soluzione evita la duplicazione delle tabelle o il ricorso a gerarchie di ereditarietà, mantenendo lo schema compatto e coerente.

Lo schema rispetta la terza forma normale. La prima forma normale è garantita dall'atomicità dei valori e dall'assenza di attributi multivalore: le relazioni molti-a-molti sono espresse tramite tabelle di giunzione anziché con campi ripetuti. La seconda forma normale è soddisfatta anche nella tabella asset_servizio, dotata di chiave primaria composita, poiché gli attributi non chiave dipendono dall'intera chiave e non da una sua parte. La terza forma normale è rispettata in quanto non sussistono dipendenze transitive: a titolo di esempio, i dati del fornitore sono separati da quelli del contratto, cosicché un fornitore con più contratti non replica le proprie informazioni, e la categoria del tipo di asset è ricavata tramite join dalla tabella di lookup anziché essere ripetuta in ogni asset.

Sono state introdotte due denormalizzazioni consapevoli e documentate, motivate da esigenze di efficienza. La prima consiste nel mantenere l'identificatore dell'organizzazione anche in tabelle che vi sono già collegate in modo indiretto, così da consentire interrogazioni di profilo per singola organizzazione senza join profondi. La seconda riguarda la conservazione di un campo di ultimo aggiornamento sulle tabelle principali, ricavabile in linea di principio dallo storico ma mantenuto per semplicità di accesso. In entrambi i casi la ridondanza è controllata e non compromette la coerenza dei dati.

Il requisito di versionamento e di storico è soddisfatto da più meccanismi complementari. Il primo è un trigger di tipo BEFORE UPDATE sulla tabella asset che, ad ogni modifica, confronta i valori precedenti e nuovi mediante un operatore che gestisce correttamente anche i valori nulli e registra automaticamente, in una tabella di storico immutabile, ogni variazione di sette campi rilevanti: nome, categoria, stato, tipo di asset, sede, versione del software e indirizzo IP. Per ciascuna modifica vengono memorizzati il valore precedente, il valore nuovo, l'autore e la marca temporale. L'autore è ricavato da una variabile di sessione che l'applicazione può impostare, con ripiegio sull'utente di database, rendendo il registro utilizzabile come traccia di conformità. Un trigger analogo aggiorna automaticamente il campo di ultimo aggiornamento.

Gli asset adottano inoltre una cancellazione logica: anziché essere rimossi fisicamente, vengono contrassegnati come eliminati mediante un apposito flag, cosicché le viste operative li escludono senza che la storicità del dato vada perduta. Il profilo ACN, a sua volta, è versionato in una tabella dedicata, nella quale ogni riga rappresenta una versione del profilo con un ciclo di vita esplicito

(bozza, inviato, approvato, da aggiornare); un vincolo di unicità sulla coppia organizzazione e numero di versione impedisce la presenza di versioni duplicate.

Sul piano dell'integrità, oltre ai vincoli di chiave e di dominio, sono stati definiti due indici univoci parziali che garantiscono l'esistenza di un solo proprietario attivo per ciascun asset e per ciascun servizio, prevenendo così righe duplicate nelle viste di profilo e ambiguità nell'attribuzione delle responsabilità. Le prestazioni sono garantite da tre categorie di indici: indici sulle chiavi esterne, necessari per accelerare le operazioni di join; indici sulle colonne più frequentemente utilizzate nei filtri, quali la categoria degli asset, la criticità dei servizi e la scadenza dei contratti; e indici parziali, definiti con una condizione, che riducono la dimensione delle strutture e velocizzano le interrogazioni selettive, ad esempio quelle limitate agli asset operativi o ai fornitori critici.

Per l'estrazione del profilo sono state definite cinque viste, ciascuna corrispondente a una sezione del profilo ACN: gli asset critici con il relativo proprietario, le dipendenze attive dalla catena di fornitura con i livelli di servizio, i referenti ufficiali verso l'ACN, lo stato delle misure di sicurezza e un quadro riepilogativo aggregato. Quest'ultima vista è stata implementata mediante sottoquery scalari indipendenti, in modo da evitare il prodotto cartesiano che si sarebbe generato aggregando più join contemporaneamente. Alle viste si affiancano tredici interrogazioni di esportazione che producono, per ciascuna organizzazione, altrettanti file in formato CSV, comprensivi di colonne calcolate quali la classe di disponibilità dei servizi, lo stato dei contratti, l'elenco dei servizi supportati da ciascun asset e specifiche analisi di carenza, come l'individuazione degli asset privi di proprietario o dei contratti in scadenza.

Il prodotto è corredato da un dataset di test rappresentativo, composto da cinque organizzazioni appartenenti a settori diversi (energia, infrastrutture digitali, sanità, trasporti e bancario) e da circa trecentoundici record complessivi, distribuiti su tutte le tabelle. Il dataset consente di verificare le interrogazioni e la generazione dei file CSV senza dover accedere a sistemi reali, e include volutamente situazioni significative, come contratti già scaduti e asset privi di responsabile, utili a mostrare il funzionamento delle analisi di carenza e degli avvisi. L'installazione avviene in tre passi: creazione del database, esecuzione dello script di struttura e caricamento dei dati di test, seguiti dall'eventuale esecuzione degli script di esportazione.

Al modello si affianca la rappresentazione dell'assessment di sicurezza secondo il Framework Nazionale per la Cybersecurity e la Data Protection. A tale scopo il primo livello comprende una seconda tabella di riferimento, `framework_subcategory`, che descrive le Subcategory del Core, mentre il quarto livello accoglie la tabella `assessment`, che registra per ciascuna organizzazione il livello desiderato e quello effettivamente raggiunto per ogni Subcategory. Le due tabelle completano il quadro: quelle precedenti descrivono che cosa l'organizzazione possiede e come lo protegge, queste ultime misurano quanto tale protezione si avvicini all'obiettivo che l'organizzazione si è data.

Si descrivono di seguito, in maggiore dettaglio, le principali tabelle dello schema e i loro attributi più significativi, così da chiarire il modo in cui il modello rappresenta le informazioni del profilo.

La tabella `organizzazione` conserva la denominazione del soggetto, il codice fiscale, il settore e la categoria NIS2, la casella di posta elettronica certificata, il sito web e la data di registrazione presso l'ACN, oltre a un indicatore di stato attivo. Alcuni campi di servizio, quali gli istanti di creazione e di ultimo aggiornamento, ne consentono la tracciabilità temporale. La tabella `sede` descrive le

sedi fisiche dell'organizzazione, con indirizzo, città, codice postale e paese, e un indicatore che individua la sede principale; a ciascuna sede possono essere associati gli asset in essa collocati.

La tabella asset, centrale nel modello, conserva per ogni risorsa un codice di inventario univoco, il nome, la descrizione, la tipologia, la categoria di criticità, lo stato operativo, l'eventuale indirizzo IP e la versione del software, oltre ai campi di audit e all'indicatore di cancellazione logica. La tabella servizio registra, per ciascun servizio, il nome, la descrizione, il tipo, la criticità, lo stato e i parametri di continuità operativa, ossia il tempo massimo di ripristino e la massima perdita di dati tollerata, espressi in ore.

La tabella fornitore raccoglie la ragione sociale, il codice identificativo, il paese, la tipologia e l'indicazione di criticità del fornitore. La tabella contratto ne formalizza i rapporti con l'organizzazione, riportando il numero, le date di inizio e di scadenza, l'oggetto, il livello di servizio garantito in termini di disponibilità percentuale, la presenza di clausole di sicurezza e il valore economico annuo. La tabella dipendenza collega un asset o un servizio a un fornitore, specificando la tipologia di dipendenza (licenza, hosting, manutenzione, connettività, servizi cloud e altre) e il livello di criticità, e facendo eventualmente riferimento al contratto che la regola.

La tabella persona descrive i referenti dell'organizzazione, con nome, cognome, contatti, ruolo organizzativo e l'indicazione del referente ufficiale verso l'ACN. La tabella responsabilita associa ciascuna persona a un asset o a un servizio con un ruolo specifico, quale proprietario, gestore o contatto tecnico, e con una validità temporale che consente di storicizzare gli avvicendamenti. La tabella asset_storico, alimentata dal trigger, conserva in modo immutabile la cronologia delle modifiche.

La tabella misura_sicurezza traccia le misure adottate ai sensi dell'articolo 21, riportando il riferimento normativo puntuale, la categoria, il nome, lo stato di attuazione e le date di implementazione e di verifica. Le categorie previste rispecchiano gli ambiti indicati dalla direttiva: la governance e la gestione del rischio, la gestione degli incidenti, la continuità operativa, la sicurezza della catena di fornitura, la crittografia, il controllo degli accessi e la gestione delle vulnerabilità. La tabella profilo_acn, infine, conserva le versioni del profilo compilato, con il riferimento alla persona che le ha redatte, il numero di versione, lo stato e la data di compilazione.

La tabella framework_subcategory costituisce il riferimento alle Subcategory del Core: per ciascuna conserva il codice identificativo, ad esempio ID.AM-01, la Funzione e la Categoria di appartenenza e la descrizione ufficiale tratta dall'edizione 2025 del Framework. A essa fa riferimento anche la tabella misura_sicurezza, attraverso il campo subcategory_cod, così da rendere esplicito quale requisito del Framework ciascuna misura concretamente soddisfa.

La tabella assessment associa a ogni organizzazione e a ogni Subcategory due valori espressi su una scala da zero a quattro, nella quale zero indica l'assenza di presidio e quattro un presidio ottimizzato: il livello target, che definisce l'obiettivo, e il livello attuale, rilevato in sede di valutazione. Completano la registrazione la priorità attribuita alla Subcategory, il livello di maturità e la data della rilevazione. Un vincolo di unicità sulla coppia organizzazione e Subcategory garantisce che per ciascuna combinazione esista una sola valutazione corrente.

Il confronto fra i due profili è esposto da quattro viste dedicate. Le viste v_profilo_target e v_profilo_attuale restituiscono rispettivamente lo stato desiderato e quello rilevato; la vista v_gap_analysis calcola, per ciascuna Subcategory, la differenza fra i due livelli e la qualifica come raggiunta o da colmare, ordinando i risultati per priorità e ampiezza dello scostamento, in modo da costituire una vera e propria roadmap; la vista v_gap_dashboard, infine, sintetizza per ciascuna

organizzazione le Subcategory raggiunte, quelle ancora da colmare e la percentuale complessiva di completamento del profilo.

Applicata al dataset di prova, la misurazione restituisce valori coerenti con la maturità delle diverse organizzazioni: il soggetto del settore bancario raggiunge circa il novantuno per cento del proprio profilo target e quello sanitario l'ottantaquattro per cento, mentre l'operatore del settore dei trasporti si ferma intorno al ventidue per cento, con una roadmap di intervento sensibilmente più ampia.

Le tredici interrogazioni di esportazione producono altrettante viste tabellari del profilo, pensate per essere salvate in file distinti e riutilizzabili. Nel dettaglio, esse generano l'anagrafica del soggetto con il referente ACN; l'elenco completo dei referenti; l'inventario degli asset critici e importanti con il proprietario e i servizi supportati; il perimetro dei servizi erogati con la classe di disponibilità; le dipendenze dalla catena di fornitura con lo stato dei contratti; lo stato delle misure di sicurezza; un quadro riepilogativo dei contatori chiave; l'avviso sui contratti scaduti o in scadenza; l'analisi degli asset privi di proprietario; l'analisi delle misure non ancora attuate; e lo storico delle modifiche agli asset. A queste si aggiungono due viste di confronto sintetico fra tutte le organizzazioni registrate, utili a una lettura d'insieme.

Alcune di queste interrogazioni non si limitano a estrarre i dati, ma li elaborano per produrre informazioni derivate: la classe di disponibilità di un servizio viene calcolata a partire dal tempo di ripristino, lo stato di un contratto (valido, in scadenza o scaduto) viene determinato confrontando la data di scadenza con la data corrente, e gli avvisi segnalano con una priorità graduata le situazioni che richiedono attenzione. In questo modo la base dati assume anche una funzione di supporto alle decisioni, evidenziando le carenze prima che si traducano in criticità.

La correttezza dello schema può essere verificata mediante interrogazioni di controllo che confrontano il numero di oggetti creati e di record inseriti con i valori attesi, nonché attraverso l'ispezione delle viste, che restituiscono immediatamente le porzioni del profilo pronte all'uso. Tale verifica è stata condotta sistematicamente durante lo sviluppo, assicurando che ogni modifica allo schema mantenesse la coerenza complessiva del sistema.

Il diagramma Entità-Relazione evidenzia con chiarezza la struttura delle dipendenze tra le tabelle. Dall'organizzazione dipendono direttamente le sedi, gli asset, i servizi, le persone, i contratti, le dipendenze, le misure di sicurezza e i profili. Gli asset, a loro volta, sono collegati al tipo che li classifica, alla sede che li ospita, allo storico delle modifiche, alle associazioni con i servizi, alle dipendenze, alle responsabilità e alle misure. I servizi sono collegati alle medesime tabelle associative, mentre i fornitori sono collegati ai contratti e alle dipendenze, e le persone alle responsabilità e ai profili. Le cardinalità, tutte del tipo uno-a-molti, sono rese esplicite nel diagramma e trovano riscontro nelle chiavi esterne dello schema.

Dal punto di vista dell'installazione, il sistema è concepito per essere messo in esercizio in modo semplice e ripetibile. Dopo aver creato un database dedicato, si esegue lo script di struttura, che definisce tabelle, vincoli, indici, funzioni, trigger e viste e popola la sola tabella di riferimento delle tipologie di asset; si carica quindi lo script dei dati di test, che riempie le restanti tabelle e riallinea i contatori automatici degli identificatori. A questo punto il sistema è pronto e le viste restituiscono immediatamente le porzioni del profilo. La separazione tra lo script di struttura e quello dei dati consente di ricreare l'ambiente da zero e di sostituire agevolmente il dataset di prova con dati reali.

La strategia di indicizzazione è stata calibrata sulle interrogazioni effettivamente utilizzate. Poiché il sistema di gestione non crea automaticamente indici sulle chiavi esterne, questi sono stati aggiunti esplicitamente per tutte le colonne coinvolte nei join; gli indici sulle colonne di filtro

accelerano le ricerche più ricorrenti, come quelle per categoria di asset o per scadenza dei contratti; gli indici parziali, infine, si applicano soltanto a un sottoinsieme di righe, riducendo lo spazio occupato e il tempo di ricerca, come nel caso dell'indice sui soli asset operativi o su quello dei soli fornitori critici.

Il rispetto della terza forma normale ha comportato scelte precise anche nella disposizione dei dati. Le informazioni geografiche, ad esempio, risiedono nella tabella delle sedi e non vengono ripetute negli asset, che vi fanno semplicemente riferimento; analogamente, i dati anagrafici dei fornitori non compaiono nelle dipendenze, ma sono raggiunti tramite la chiave esterna. Questo garantisce che un'eventuale variazione di un dato, come il cambio di ragione sociale di un fornitore, debba essere effettuata in un unico punto, con evidente beneficio per la coerenza complessiva della base dati.

A titolo di esempio, se un asset inizialmente classificato come importante viene rivalutato come critico a seguito di un'analisi del rischio, il trigger registra automaticamente la variazione della categoria, conservando il valore precedente, quello nuovo, l'autore e il momento della modifica, insieme all'eventuale motivazione fornita dall'applicazione. La medesima logica si applica al cambio di stato di un asset, ad esempio quando viene posto in manutenzione, o all'aggiornamento della versione del software installato. Il registro così costituito consente di ricostruire in ogni momento la storia di ciascun asset, requisito prezioso sia per finalità di audit sia per l'analisi a posteriori degli incidenti.

Il dataset di prova, infine, è stato costruito in modo da esercitare tutte le funzionalità dello schema. Le cinque organizzazioni presentano configurazioni differenti per numero di asset, di servizi e di dipendenze, e includono situazioni volutamente eterogenee: profili in stato di bozza, inviato, approvato o da aggiornare; misure di sicurezza in diversi stati di attuazione; contratti validi e contratti già scaduti; asset dotati di proprietario e asset intenzionalmente privi di responsabile. Questa varietà consente di verificare non solo il caso nominale, ma anche le situazioni limite che le interrogazioni di analisi sono chiamate a individuare.

Per illustrare concretamente l'implementazione, si riportano di seguito alcuni estratti significativi del codice SQL dell'elaborato, tratti rispettivamente dallo script di struttura, da quello di popolamento e da quello di estrazione. Gli estratti sono stati abbreviati e semplificati rispetto al codice completo per finalità espositive.

Un primo esempio riguarda la definizione di una tabella con i relativi vincoli. La tabella delle dipendenze mostra l'uso combinato di chiavi esterne con azioni referenziali, di vincoli di dominio sui valori ammessi (CHECK) e del vincolo che impone la valorizzazione di almeno una fra asset e servizio:

```
CREATE TABLE dipendenza (  
    id SERIAL PRIMARY KEY,  
    organizzazione_id INT NOT NULL REFERENCES organizzazione (id) ON DELETE CASCADE,  
    asset_id INT REFERENCES asset (id) ON DELETE CASCADE,  
    servizio_id INT REFERENCES servizio (id) ON DELETE CASCADE,  
    fornitore_id INT NOT NULL REFERENCES fornitore (id),  
    tipo_dipendenza VARCHAR(30) NOT NULL  
        CHECK (tipo_dipendenza IN ('licenza','hosting','manutenzione',  
                                   'connettivita','saas','paas','iaas','altro')),  
    criticita VARCHAR(10) NOT NULL DEFAULT 'media'  
        CHECK (criticita IN ('critica','alta','media','bassa')),  
    CONSTRAINT chk_dip_asset_o_servizio  
        CHECK (asset_id IS NOT NULL OR servizio_id IS NOT NULL)  
);
```

Il meccanismo di storicizzazione è realizzato dalla funzione trigger seguente, che ricava l'autore della modifica da una variabile di sessione e registra le variazioni dei campi monitorati confrontando il valore precedente con quello nuovo:

```
CREATE OR REPLACE FUNCTION fn_audit_asset()
RETURNS TRIGGER LANGUAGE plpgsql AS $$
DECLARE
    v_utente TEXT := COALESCE(
        NULLIF(current_setting('nis2.utente', TRUE), ''), current_user);
BEGIN
    IF NEW.categoria IS DISTINCT FROM OLD.categoria THEN
        INSERT INTO asset_storico
            (asset_id, campo_modificato, valore_precedente, valore_nuovo,
            modificato_da)
            VALUES (OLD.id, 'categoria', OLD.categoria, NEW.categoria, v_utente);
    END IF;
    -- analogamente per stato, tipo_asset_cod, versione_sw, ip_address, ...
    RETURN NEW;
END;
$;
```

La regola che ammette un solo proprietario attivo per ciascun asset è imposta da un indice univoco parziale, applicato cioè soltanto alle righe che soddisfano una condizione:

```
CREATE UNIQUE INDEX uq_asset_proprietario_attivo
ON responsabilita (asset_id)
WHERE tipo_responsabilita = 'proprietario'
AND data_fine IS NULL
AND asset_id IS NOT NULL;
```

Il popolamento di prova avviene con istruzioni di inserimento come la seguente, relativa a un asset di tipo server dell'organizzazione del settore energetico:

```
INSERT INTO asset
(id, organizzazione_id, sede_id, tipo_asset_cod, codice_inventario,
 nome, categoria, stato, ip_address, versione_sw)
VALUES
(1, 1, 2, 'SERVER_FISICO', 'INV-AE-001',
 'SCADA Server Primario', 'critico', 'attivo', '10.0.1.10', 'SCADA 6.2.1');
```

Infine, le interrogazioni di estrazione non si limitano a leggere i dati, ma li elaborano per produrre informazioni derivate. Nell'estratto seguente lo stato del contratto viene calcolato al momento dell'esecuzione confrontando la data di scadenza con la data corrente:

```
SELECT COALESCE(a.nome, sv.nome) AS risorsa,
       f.nome AS fornitore,
       CASE WHEN c.data_scadenza < CURRENT_DATE THEN 'SCADUTO'
            WHEN c.data_scadenza <= CURRENT_DATE + INTERVAL '90 days'
            THEN 'In scadenza'
            ELSE 'Valido' END AS stato_contratto
FROM dipendenza d
JOIN fornitore f ON f.id = d.fornitore_id
LEFT JOIN contratto c ON c.id = d.contratto_id
WHERE d.organizzazione_id = 1 AND d.data_fine IS NULL;
```


Un ultimo esempio riguarda il calcolo del divario fra profilo target e profilo attuale, che costituisce il nucleo della vista di gap analysis:

```
SELECT o.nome AS organizzazione, a.subcategory_cod,  
       a.priorita, a.livello_target, a.livello_attuale,  
       (a.livello_target - a.livello_attuale) AS gap,  
       CASE WHEN a.livello_attuale >= a.livello_target THEN 'Raggiunto'  
            ELSE 'Da colmare' END AS stato  
FROM assessment a  
JOIN organizzazione o ON o.id = a.organizzazione_id  
ORDER BY CASE a.priorita WHEN 'alta' THEN 1 WHEN 'media' THEN 2 ELSE 3 END,  
          (a.livello_target - a.livello_attuale) DESC;
```

Questi estratti, pur nella loro sinteticità, testimoniano l'uso coordinato dei principali strumenti offerti dal sistema di gestione: vincoli dichiarativi per l'integrità, trigger per l'automazione dell'audit, indici per le prestazioni e l'integrità, e interrogazioni evolute per la generazione del profilo.

Merita un approfondimento il tema dei compromessi progettuali (trade-off). Ogni scelta di modellazione comporta un bilanciamento tra obiettivi in tensione tra loro, quali la purezza formale dello schema, l'efficienza delle interrogazioni e la semplicità d'uso. Nel presente elaborato sono state adottate, in modo consapevole e documentato, alcune soluzioni che si discostano dalla forma normale più restrittiva, ciascuna motivata da un vantaggio concreto.

La prima riguarda la presenza dell'identificatore dell'organizzazione anche in tabelle che vi sono già collegate in modo indiretto, come quella delle dipendenze: si tratta di una ridondanza controllata che, a fronte di una minima duplicazione del dato, consente di estrarre il profilo di una singola organizzazione senza attraversare lunghe catene di join, con beneficio in termini di prestazioni e di leggibilità delle interrogazioni. La seconda riguarda la conservazione, sulle tabelle principali, di un campo di ultimo aggiornamento che sarebbe in linea di principio ricavabile dallo storico, ma che viene mantenuto per semplicità di accesso. Un ulteriore compromesso è rappresentato dalla scelta di modellare le chiavi esterne facoltative verso asset e servizio con un vincolo di controllo, in luogo di soluzioni basate sull'ereditarietà o su tabelle distinte: la soluzione adottata privilegia la compattezza e la chiarezza dello schema. Analogamente, la cancellazione logica degli asset antepone la conservazione della storicità alla minimizzazione dello spazio occupato. In tutti i casi, la ridondanza introdotta è controllata e non compromette la coerenza complessiva dei dati.

A completamento della documentazione sono state definite alcune linee guida per il popolamento e la manutenzione dei dati. In fase di inserimento si raccomanda di rispettare l'ordine di caricamento imposto dalle dipendenze referenziali, popolandolo dapprima le entità principali e successivamente le tabelle associative; di valorizzare sempre i campi che classificano gli asset e i servizi per criticità, essenziali ai fini delle estrazioni; e di impostare la variabile di sessione che identifica l'autore delle modifiche, così da alimentare correttamente il registro di audit. In fase di manutenzione, la cancellazione logica va preferita a quella fisica, le associazioni terminate vanno chiuse valorizzandone la data di fine anziché eliminandole, e ogni nuova versione del profilo va tracciata nell'apposita tabella.

L'elaborato comprende le istruzioni di installazione precise, che ne consentono la messa in esercizio in un ambiente pulito. I prerequisiti sono un'installazione di PostgreSQL in versione 14 o superiore, un database dedicato, un utente con privilegi sufficienti a eseguire istruzioni di

definizione dei dati e la disponibilità del client a riga di comando. L'installazione si articola in pochi passi, da eseguire nell'ordine indicato tramite Windows Powershell:

```
Inizializzazione db:
& "C:\Program Files\PostgreSQL\18\bin\createdb.exe" -U postgres nis2db

Creazione schema dati db:
& "C:\Program Files\PostgreSQL\18\bin\psql.exe" -U postgres -d nis2db -f
nis2_schema.sql

Popolazione db:
& "C:\Program Files\PostgreSQL\18\bin\psql.exe" -U postgres -d nis2db -f
nis2_testdata.sql

Export dati db in csv (eseguire da cartella "csv", versione con separatore ','):
& "C:\Program Files\PostgreSQL\18\bin\psql.exe" -U postgres -d nis2db -f
..\sql\nis2_export_csv.sql
```

Il primo comando crea il database; il secondo carica la struttura completa, comprensiva dei vincoli, degli indici, delle funzioni, dei trigger e delle viste, insieme ai dati di riferimento delle tipologie di asset; il terzo popola le restanti tabelle con il dataset di prova; il quarto genera i file CSV dei profili. La selezione dell'organizzazione da esportare avviene tramite un parametro, e i file vengono prodotti nella cartella di lavoro corrente. È inoltre disponibile una procedura lato server per l'esportazione verso un percorso personalizzato, subordinata però a privilegi amministrativi.

Particolare attenzione è stata dedicata alla gestione dell'evoluzione dello schema nel tempo, requisito esplicito della traccia. La procedura raccomandata prevede di raccogliere le modifiche in file di migrazione dedicati, contenenti le sole istruzioni differenziali di alterazione delle tabelle o di creazione di nuovi indici, e di eseguirle all'interno di una transazione, così da garantirne l'atomicità: se una qualsiasi istruzione fallisce, l'intera migrazione viene annullata, evitando stati intermedi incoerenti. Ove necessario, i contatori automatici degli identificatori vengono riallineati e lo stato dei profili interessati viene aggiornato per segnalarne la necessità di revisione. La suddivisione del codice in file distinti, unita all'uso di un sistema di controllo di versione, completa la strategia di gestione delle versioni e assicura la tracciabilità delle modifiche apportate al prodotto.

La verifica del prodotto è affidata a un dataset simulato e a un insieme di controlli, che consentono di collaudare le interrogazioni e la generazione dei file senza accedere a sistemi reali, come espressamente richiesto dalla traccia. Il dataset comprende cinque organizzazioni e circa trecentoundici record complessivi, distribuiti su tutte le tabelle secondo conteggi noti e verificabili.

La correttezza dell'installazione può essere accertata confrontando il numero degli oggetti creati con quello previsto: lo schema definisce sedici tabelle, nove viste, due funzioni e sei trigger, oltre a un ampio insieme di indici. Analogamente, il numero dei record inseriti in ciascuna tabella è confrontabile con i valori attesi, ad esempio ventinove asset, quindici servizi, venti dipendenze e venticinque misure di sicurezza. L'esecuzione delle viste restituisce immediatamente le porzioni del profilo, offrendo un ulteriore riscontro della coerenza dei dati. Il dataset include volutamente casi limite, quali contratti già scaduti e asset privi di responsabile, che consentono di verificare il corretto funzionamento delle analisi di carenza e degli avvisi: in tal modo il collaudo non si limita al caso nominale, ma copre anche le situazioni che il sistema è chiamato a segnalare.

Nel complesso, l'elaborato si concretizza nei quattro artefatti previsti dalla traccia, tra loro coerenti e riconducibili alla medesima versione del prodotto.

Il primo artefatto è costituito dagli script SQL e dallo schema del database, organizzati in un repository e comprensivi delle istruzioni di creazione delle tabelle con i relativi vincoli di chiave primaria ed esterna, degli indici e dei vincoli di integrità, delle funzioni e dei trigger per la gestione del versionamento e dello storico, e degli script di popolamento con dati di test rappresentativi. Il secondo artefatto è rappresentato dalle interrogazioni che producono l'output strutturato in formato CSV utile al profilo ACN, comprese le viste che estraggono, per ciascuna azienda, l'elenco degli asset critici, dei servizi erogati, delle dipendenze da terze parti e dei punti di contatto. Il terzo artefatto è la documentazione tecnica e il modello concettuale, che comprende il diagramma Entità-Relazione, il data dictionary con la descrizione di ogni tabella e campo, l'illustrazione delle scelte di normalizzazione e dei relativi compromessi e le istruzioni di installazione e manutenzione. Il quarto artefatto, infine, è il dataset simulato con i relativi controlli, che consente di verificare le interrogazioni e la generazione dei file senza accedere a sistemi reali. La presenza e la coerenza di tutti e quattro gli artefatti assicurano la piena rispondenza dell'elaborato a quanto richiesto dalla traccia.

Campi di applicazione

(Descrivere gli ambiti di applicazione dell'elaborato progettuale e i vantaggi derivanti della sua applicazione):

Il prodotto è applicabile a qualsiasi organizzazione soggetta alla direttiva NIS2, indipendentemente dal settore di appartenenza: energia, trasporti, sanità, banche, infrastrutture digitali, pubblica amministrazione e fornitori di servizi ICT. La struttura dello schema è deliberatamente indipendente dal settore, cosicché il medesimo modello può essere riutilizzato in contesti differenti senza modifiche strutturali, limitandosi a valorizzare diversamente gli attributi che descrivono il settore e la categoria del soggetto.

In termini operativi, la base dati può essere impiegata per mantenere un inventario aggiornato e auditabile degli asset critici e importanti; per mappare il perimetro dei servizi essenziali e digitali con i relativi obiettivi di continuità; per censire le dipendenze dai fornitori terzi, con i relativi contratti e livelli di servizio, a supporto della gestione del rischio della catena di fornitura; per tracciare le responsabilità organizzative associate ad asset e servizi; per monitorare lo stato di attuazione delle misure di sicurezza previste dall'articolo 21; e, infine, per estrarre automaticamente le sezioni del profilo ACN in formato strutturato, pronte per essere trasmesse o integrate in altri sistemi.

I vantaggi derivanti dall'applicazione sono molteplici. La normalizzazione garantisce la coerenza e la non ridondanza dei dati; l'audit trail e il versionamento ne assicurano l'aggiornabilità e la tracciabilità nel tempo; l'automazione delle estrazioni riduce gli errori manuali e rende le operazioni ripetibili; le analisi di carenza e gli avvisi consentono di individuare tempestivamente situazioni critiche, quali asset privi di responsabile o contratti in scadenza, trasformando la base dati da semplice archivio a strumento di supporto alle decisioni. Il prodotto può inoltre costituire il livello dati su cui innestare un applicativo gestionale o integrazioni con sistemi preesistenti.

A titolo esemplificativo, un operatore del settore energetico può impiegare la base dati per censire i sistemi di supervisione e controllo e le loro dipendenze dai fornitori di manutenzione e di connettività; una struttura sanitaria può tracciare i sistemi informativi ospedalieri e i dispositivi medici connessi, con i relativi responsabili; un istituto bancario può mappare i sistemi di pagamento e le dipendenze dai circuiti interbancari. In tutti questi casi il modello resta invariato, cambiando soltanto i dati, il che testimonia la generalità della soluzione.

Il valore del prodotto non risiede unicamente nella catalogazione, ma nella possibilità di correlare le informazioni: associare gli asset ai servizi che sostengono, i servizi alle dipendenze da cui sono esposti e le misure di sicurezza agli elementi che proteggono. Questa correlazione consente di rispondere a domande rilevanti ai fini della conformità, quali l'individuazione dei servizi essenziali esposti a fornitori critici o degli asset critici privi di misure adeguate.

Un ulteriore ambito di impiego riguarda la preparazione alle attività di verifica e di audit: disponendo di un profilo strutturato e sempre aggiornato, l'organizzazione può produrre rapidamente la documentazione richiesta, ridurre i tempi di risposta alle richieste dell'autorità e dimostrare con evidenze concrete lo stato di attuazione delle misure di sicurezza.

L'integrazione del Framework Nazionale amplia ulteriormente gli impieghi possibili: la base dati consente di condurre un'autovalutazione periodica della postura di sicurezza, di documentarne l'evoluzione nel tempo confrontando rilevazioni successive e di produrre, a partire dai divari misurati, un piano di adeguamento ordinato per priorità. Ne beneficiano tanto le funzioni tecniche, che individuano gli interventi da avviare, quanto gli organi di governo, ai quali la percentuale di completamento del profilo offre un indicatore sintetico e immediatamente comprensibile dello stato di conformità.

Valutazione dei risultati

(Descrivere le potenzialità e i limiti ai quali i risultati dell'elaborato sono potenzialmente esposti)

La valutazione dei risultati è articolata distinguendo esplicitamente le potenzialità del prodotto dai suoi limiti, per poi considerare i rischi connessi e le possibili linee di sviluppo.

Potenzialità

Il principale punto di forza dell'elaborato risiede nell'aver tradotto requisiti normativi complessi in un modello dati coerente, normalizzato ed estensibile, dotato di un meccanismo di audit completo e di funzioni di esportazione standardizzate. Lo schema copre in modo organico le sezioni fondamentali del profilo richiesto dall'ACN e costituisce una base solida su cui sviluppare un applicativo gestionale o realizzare integrazioni con sistemi esistenti, quali i database di gestione della configurazione.

Rispetto alla prassi diffusa di gestire tali informazioni in fogli di calcolo, la soluzione offre garanzie di integrità e coerenza non altrimenti ottenibili: i vincoli impediscono l'inserimento di dati incoerenti, l'audit trail rende ogni modifica riconducibile a un autore e a un istante, e le viste garantiscono che le porzioni del profilo siano sempre allineate ai dati sottostanti. L'architettura, inoltre, si presta a una crescita incrementale: l'aggiunta di nuovi tipi di asset, di nuove categorie di misure o di nuovi attributi può avvenire senza stravolgere lo schema, grazie all'uso di tabelle di riferimento e di vincoli di dominio facilmente estendibili. La suddivisione modulare del codice e la documentazione a corredo ne accrescono la manutenibilità.

Un ulteriore elemento di forza deriva dall'ancoraggio a uno standard riconosciuto: adottando il Core del Framework Nazionale come riferimento, la valutazione diventa ripetibile nel tempo e confrontabile fra organizzazioni diverse, e la base dati si trasforma da semplice registro in strumento di misurazione e di pianificazione.

Limiti

Occorre d'altra parte riconoscere alcuni limiti. Il modello rappresenta una semplificazione, per quanto estensibile, del profilo ACN: non copre la totalità dei campi previsti dalla normativa, che può inoltre evolvere nel tempo. I dati utilizzati sono simulati e non provengono da sistemi reali, e come tali servono a dimostrare il funzionamento del sistema ma non a rappresentare una situazione effettiva.

Sul piano funzionale, manca un livello applicativo con interfaccia utente, autenticazione e controllo degli accessi e validazioni di business; l'interazione avviene quindi direttamente sul database. L'esportazione lato server tramite procedura dedicata richiede inoltre privilegi amministrativi, ragione per cui, nell'uso ordinario, si è privilegiata l'esportazione lato client. Infine, la gestione del flusso di notifica degli incidenti, pur prevista dalla direttiva, non rientra nel perimetro dell'elaborato, che si concentra sulla rappresentazione del profilo del soggetto.

Con riguardo all'assessment, va inoltre precisato che il modello recepisce un sottoinsieme rappresentativo delle Subcategory del Core e non la loro totalità, e che i livelli target e attuali presenti nel dataset sono ipotizzati a fini dimostrativi: in un impiego reale essi dovrebbero derivare da una rilevazione condotta secondo la metodologia di assessment, con il coinvolgimento delle funzioni competenti.

Rischi e misure di mitigazione

I risultati sono potenzialmente esposti al rischio di disallineamento rispetto ai formati ufficiali del profilo ACN, qualora questi vengano aggiornati, nonché alla necessità di adeguare vincoli e viste in caso di estensione del modello. Tali rischi sono in buona parte mitigati dalla modularità degli script, che consente di intervenire su una singola componente senza ricostruire l'intero sistema, e dalla presenza di una documentazione tecnica che rende espliciti gli assunti progettuali.

Sviluppi futuri

Tra i possibili sviluppi futuri si segnalano l'introduzione di un'interfaccia applicativa con autenticazione e profili di accesso basati sui ruoli; l'esposizione di interfacce di programmazione per l'integrazione con altri sistemi; l'arricchimento del catalogo delle misure di sicurezza e la loro mappatura puntuale verso i moduli ufficiali dell'ACN; l'aggiunta di una gestione strutturata delle notifiche di incidente; e l'automazione della generazione periodica dei profili.

In sintesi, i risultati conseguiti sono coerenti con le finalità della traccia e con gli obiettivi didattici del percorso: il prodotto è funzionante, documentato e verificato, e i suoi limiti sono chiaramente individuati, così da costituire un punto di partenza consapevole per eventuali sviluppi successivi.